

External Penetration Testing Report

Prepared For: MD. Shadman Sadique

Prepared By: Md Mehedi Hasan

Assessment Scope:

Active Reconnaissance
OWASP Juice Shop
Blue Room Exploita

Date: 18 May 2026

Section 1 — Executive Summary

This report presents the findings from three practical security assessments conducted in controlled lab environments: Active Reconnaissance, OWASP Juice Shop, and the Blue (MS17-010) vulnerable Windows machine. The purpose of these exercises was to identify common weaknesses in networks, web applications, and operating systems and evaluate their potential impact.

The assessments revealed multiple security issues, including information disclosure, authentication bypass, SQL Injection vulnerabilities, and remote code execution through unpatched services. Successful exploitation demonstrated how attackers can gather sensitive information, gain unauthorized access, escalate privileges, and fully compromise systems.

These findings emphasize the importance of strong security practices such as timely patch management, secure application development, service hardening, and continuous monitoring.

Section 2 — Scope of Assessment

In Scope

- TryHackMe Active Reconnaissance Room
- OWASP Juice Shop Vulnerable Web Application
- Blue Windows Machine (MS17-010 / EternalBlue)

Out of Scope

- Real-world production systems
- Third-party infrastructure and services
- Denial-of-Service (DoS) attacks
- Social engineering activities

Section 3 — Methodology

The assessment followed a standard penetration testing lifecycle consisting of the following phases:

1. Reconnaissance

Information gathering was performed to identify live hosts, open ports, running services, and publicly accessible information.

2. Vulnerability Analysis

Discovered services and applications were analyzed for known vulnerabilities, weak configurations, and insecure coding practices.

3. Exploitation

Controlled exploitation techniques were used to validate vulnerabilities and assess their impact.

4. Post-Exploitation

Privilege escalation, credential extraction, and system access verification were performed to determine the extent of compromise.

5. Reporting

All findings, associated risks, impacts, and remediation recommendations were documented.

Section 4 — Active Reconnaissance Summary

Tools Used

- ping
- traceroute
- telnet
- netcat
- Browser Developer Tools

Key Findings

- Information disclosure through HTTP headers and JavaScript files
- ICMP responses revealed active hosts and possible operating system details
- Traceroute exposed internal routing paths and network structure
- Banner grabbing revealed service versions and technologies in use

Security Impact

- Attackers can use disclosed information to identify exploitable services
- Network mapping improves targeting accuracy during attacks
- Exposed service versions may allow vulnerability matching

Recommendations

- Disable unnecessary service banners and metadata exposure
- Restrict ICMP responses where appropriate
- Limit traceroute visibility through firewall configurations
- Replace insecure protocols such as Telnet with SSH
- Minimize publicly exposed technical information

Section 5 — OWASP Juice Shop Summary

Key Findings

- Sensitive information disclosure through application functionality
- Broken authentication allowing login bypass
- SQL Injection vulnerabilities in authentication forms

Security Impact

- Unauthorized access to user and administrator accounts
- Potential exposure of sensitive customer data
- Possibility of privilege escalation and database compromise

Recommendations

- Use parameterized queries and prepared statements
- Validate and sanitize all user inputs
- Implement secure session and authentication controls
- Enforce strong password policies and MFA where applicable
- Conduct secure code reviews and regular application testing

Section 6 — Blue Room Summary

Vulnerability

MS17-010 (EternalBlue SMB Vulnerability)

Key Findings

- SMB service exposed on TCP port 445
- Successful remote code execution using EternalBlue exploit
- SYSTEM-level privileges obtained
- Credential hashes successfully extracted and cracked

Security Impact

- Complete system compromise
- Credential theft enabling lateral movement
- Unauthorized access to sensitive system resources
- Potential spread of malware or ransomware across networks

Recommendations

- Apply Microsoft MS17-010 security patches immediately
 - Disable SMBv1 protocol
 - Restrict access to port 445 using firewall rules
 - Enable endpoint protection and credential protection features
 - Monitor SMB traffic for suspicious activity
-

Section 7 — General Security Recommendations

- Maintain regular patch management processes
- Use secure coding practices throughout development
- Perform routine vulnerability assessments and penetration testing
- Disable outdated and insecure protocols/services
- Implement centralized logging and monitoring
- Apply the principle of least privilege
- Conduct security awareness training for users and administrators
- Use endpoint detection and response (EDR) solutions

Section 8 — Conclusion

The assessments demonstrate how weak configurations, insecure application design, and outdated systems can expose organizations to serious cybersecurity threats. Vulnerabilities such as SQL Injection and EternalBlue can allow attackers to gain unauthorized access, escalate privileges, and compromise entire systems.

Organizations can significantly reduce these risks by implementing secure development practices, maintaining proper patch management, restricting unnecessary services, and continuously monitoring their environments for suspicious activity.